

1. Objective & Methodology :-

An organization has commissioned an external penetration test to determine how much information an Authorized attacker could gather about its internal facing infrastructure without directly attacking its system. using the Harvester against the Authorized domain tesla.com, conduct a comprehensive scan to identify publicly available email addresses, subdomains, IP addresses, URLs, & other relevant infrastructure.

Method required tools :- the Harvester

Commands used :-

- The Harvester -d tesla.com -b hackerforget
- The Harvester -d tesla.com -b hackerforget -f tesla-hacker
- is -lh tesla-hackerforget
- The Harvester -d tesla.com -b hackerforget

output :-

- *) Accounts. tesla.com: 93.222.124.64
- *) Am513-gpwl. tesla.com: 199.120.50.30
- auth-eng. usa.vucloud. tesla.com. 66.12.8.3

- ②
- Accounts.tesla.com: 23.222.124.64
 - ams13-gpywl.tesla.com: 199.120.50.30
 - akamai-apigateway-votidextingfogw-prd310.st.tesla.com: 23.62.10.65
 - apac-cppm.tesla.com: 23.202.44.07

- ③
- rw-r--r-- kali kali 3.4K Aug 19 09:12 tesla-hacker target.ison
 - +rw-r--r-- kali kali 6.1K Aug 19 09:12 tesla-hacker target.xml

- ④
- Accounts.tesla.com: 23.222.124.64
 - akamai-apigateway-rach.claextinfungw-prd310.st.tesla.com: 23.62.10.61
 - ams13-gpywl.tesla.com: 199.120.50.30
 - apac-cppm.tesla.com: 23.202.44.17

2. Objective & Methodology :-

A penetration test was carried out against the publicly accessible intentionally vulnerable web application test.php.vulnweb.com using mitos to identify exposed files & directories, in search of secure HTTP methods, server configuration weakness information disclosure issues outdated

Components dangerous files

Required Tool:- NIKTO

Commands used:-

- nikto -h http://testphp.vulnweb.com
- nikto -h http://testphp.vulnweb.com -o nikto-testphp-report
- html -format html
- nikto -h http://testphp.vulnweb.com -turning 1,2,3,4,6,9
- cat nikto-testphp-report.html //css

Output:-

① Banner & headers findings:-

- * Nikto v2.x scan on test.php.vulnweb.com
- server: nglnx (banner captured from the pipcon)
- * The X-Content-Type-options header is not set
- Cookie plt pscod created without the help file.

② file/directory:-

- Allowed HTTP methods : Get, Head, Post, options, trace.

- /admin/: Admin login page/ action found.

→ /usr/bin/entries or /usr/bin/entries : very control metadata file found.

③ outdated Component:-

- outdated version of PHP in server / is powered by header
- /list_products.php cat:1 = possible SQL-injection entrypoint

④ Confirms & Consolidated:-

- find requests: 0 errors(s) & N items (ks) reported

3.

Objective & Methodology:-

An external DNS Security Assessment was performed against the Authorized domain zone from mc using the dig utility, to enumerate all standard DNS record types identify the authoritative servers & determine whether an Authorized zone transfer could be performed. zone transfer mc is a domain maintained with a purpose.

Required tool:- Dig

Commands:-

- dig → zone transfer mc
- dig MX zone transfer mc

- dig ns zone transfer .mc
- dig txt zone transfer .mc
- dig soa zone transfer .mc
- dig axfr zone transfer .ms @ ns2tmj. dig. n^on^oa

output:-

① A record:-

∴ Answer Section:-

zone transfer .mc 7200 IN a < restored IP from live run

② MS record:-

→ zone transfer .mc 7200 MX 0 ASPMX.L. Google.com

③ NS Record:-

→ zone transfer .mc 7200 IN NS ns2tm1.dig.ninja

* zone transfer .mc 7200 IN NS ns2tm2.dig.ninja

④ TXT record:-

→ zone transfer .mc 7200 IN TXT < information of TXT

string from live run >

⑤ SOA record:-

→ zone transfer .mc 7200 IN SOA ns2tm1.dig

.ninja. robin.dig.ninja < serial > < refresh > < expiry >

< expire > < minimum >

⑥ AXFR zone transfer attempt:-

∴ Transfer Succeeded

www.zone transfer.mc. IN A <1:P>

office.zone transfer.mc IN A <1:P>

internal.zone transfer.mc IN A <1:P>

... Complete list of zone records returned in one responses.

④

Objective & Methodology :-

Window/SMB target 192.168.1.100 using EnumLinux, to determine what information could be obtained through SMB & BIOS enumeration before any exploitation was attempted. Enumtiling Automates the classic null session & PID-Cycling enumeration techniques against SMB

Required tool :- Enum4Linux

Commands :-

1. enum4linux -a 192.168.1.100

2. enum4linux -u 192.168.1.100

• enum4linux -s 192.168.1.100

• enum4linux -p 192.168.1.100

• enum4linux -a 192.168.1.100) + cc enum4linux 192.168.1.100

Output:-

① - a, full enumeration

*) asl domain/work group name: Work Group

*) server os: C smb - negotiated as string from line

runs

→ server is functioning as a file/print server only.

② - V users

- S - 1 - 5 - 21 ... - 500

Work Group / administrator

- S - 1 - 5 - 21 ... - 1001

Work Group / sys backup

- 1 - 5 - 21 ... 1002

Work Group / guest

③ - P. Password Policy:-

→ Minimum password length: 0

→ Password complexity flag: off

→ Account lockout threshold: None.

5) Enum u Joux - 192-168-1-100 71 + 2

(some content as Command 1, written to file)

5. Objective & Methodology :-

Sconnmc org.n map . the official test host maintained
 by Nmap project for scanning practice. using
 Netcat to connect directly to Accessible TCP
 Services & capture the banner/ response each
 service disclosure. open ports were identified
 with a quick N-map scan, & Netcat was the
 used against each open port.

Required Tool :: Netcat (nc)

Commands :

- nmap .. P ... PPort - TH- scanme - nmap.org
- nc .. x scanme.nmap.org 22
- nc .. x scanme.nmap.org 22

Output:

① Nmap port discovery

Port state service

22/tcp open ssh

80/tcp open http

② output (ssh banner group on port 22)

Connection to 3conne.nmap.org 22 port [tcp/ssh]

SSH-2.0-openssh SSH - < version captured from live

run < os-flow >

③ HTTP header group on port 80

HTTP/1.1 200 OK

Server: Apache / < version captured from live run = (cos) < cos >

==